

Quantification du risque de non-conformité DORA

La modélisation retenue, le dernier point tuteur, et quatre demandes d'appui

Kélian Kaddouri

ENSAE / Nexialog Consulting

10 août 2026

Le fil de ce point

Quinze minutes, trois temps. Je passe l'essentiel du temps sur le troisième.

Ce que je voudrais couvrir

1. **La modélisation retenue à ce jour**, en trois briques et une difficulté centrale. C'est court, mais nécessaire pour que les questions qui suivent aient un sens.
2. **Ce que le point avec mon tuteur du 7 août a produit**, dont deux corrections de fond qui touchent au vocabulaire et au statut de ce que je publie.
3. **Quatre demandes d'appui**, toutes sur la modélisation. La première appelle un arbitrage qui ne relève pas du calcul, et c'est celle sur laquelle je voudrais m'attarder.

Une seule des quatre demandes exige une décision. Les trois autres sont des questions de méthode sur lesquelles je suis bloqué ou incertain.

Trois briques, et ce que chacune apporte

L'objet est de quantifier un besoin de capital associé à un défaut de maîtrise du risque informatique, en traitant les cinq domaines d'exigences du règlement DORA comme des composantes qui se propagent l'une sur l'autre, et non comme des risques indépendants à agréger.

La fréquence

Binomiale négative pilotée par un facteur systémique commun, calibrée à 21,56 incidents informatiques matériels par an à l'échelle du secteur financier mondial. Pour descendre à une entité, la fréquence n'est pas prise dans une tranche de la base mais **lue sur une courbe** : elle est estimée comme une fonction de la taille de firme, log-actifs en covariable, l'élasticité valant 0,0744.

La sévérité

Dépassements de seuil et ajustement de Pareto généralisée au-delà de $u = 20,03$ M€, sur 91 excès : $\hat{\xi} = 0,5954$, $\hat{\sigma} = 57,97$. Cette valeur est en elle-même une information : **au-dessus de 0,5 la variance est infinie, en dessous de 1 l'espérance existe encore**. Le quantile extrême est donc porté par un sinistre unique et non par une accumulation, ce qui conditionne tout ce qui suit.

L'agrégation, où se situe l'apport : la propagation est modélisée explicitement plutôt que les marges couplées par une copule. J'y viens dans deux slides.

Sources : scripts 07, 47, 60 et 63.

Le modèle en un schéma, et le statut de chaque grandeur

Quantifier le besoin de capital DORA : de la donnée brute au capital, puis à son allocation

■ estimée sur données ■ posée, non calibrée ▲ bornée faute d'identification

● réglementaire ou standard | chaque bloc est un choix atteignable séparément, et chaque nombre est imprimé par le script indiqué à droite.

I. Les données, et ce qu'on en tire

1. Trois sources, trois rôles disjoints script 42, 43
 ■ **OpRisk Global** (SAS), 582 pertes cyber finance sur 27 ans, converties en euros → porte le niveau de sévérité.
 ■ **Privacy Rights Clearinghouse**, 15/03 incidents en nombre d'engagements, convertie par la régression de Jacobs $\ln L = 7.68 + 0.76 \ln X + \epsilon$ → axe de sévérité.
 ■ **Corpus de post-mortems**, 10 incidents et 22 transitions codées → la seule source d'ordre entre piliers.
 ■ **Hackmapeddon** : parts par vecteur secondaire, citation externe datée et non recensable, qui ne porte aucun niveau de capital.

2. Fréquence : une charge systémique commune script 48b, 49
 $Y \sim \mathcal{N}(0,1)$ tire une fois par an, commune aux cinq piliers :
 $m = \exp(\frac{1}{2}Y^2 - \frac{1}{2})$, $E[m] = 1$, $N(Y \sim \mathcal{P}(A) | m)$
 ■ $\alpha = 0.60$ positif, contre ■ $\alpha = 0.122$ négatif (IC_{50%} 0.054; 0.228) : le modèle retient donc une charge systémique plus lourde que sa propre estimation, et le dit.
 ■ $\lambda_{\text{moyenné}} = 21.56/\text{an}$, $\lambda_0 \approx \text{BDOIT}$, parts 30/27/18/15/9%
 Surdispersion observée $\text{Var}/E = 1.19$, dispersion de Pearson $\chi^2 = 2.24$.

3. Sévérité : loi recollée, corps empirique et queques CPD script 47, 48

$$P(X > x) = p_0 \left(1 + \frac{4(x - \mu)^2}{\sigma^2} \right)^{-1/c}$$

$$x > \mu$$
 ■ **OpRisk** : $\mu = 20.03$ M€, 91 excès, $\xi = 0.595$ (IC_{50%} [30.30; 0.838]), $\sigma = 57.97$ M€, $p_0 = 0.151$.
 ■ **PRC** : $\mu = 4.179$ M€, 2258 excès, $\xi = 1.033$: expérience inférieure, ce qui justifie μ plus petit de sévérité à 40 M€.
 Validité, pas surprenant : Anderson-Darling $p = 0.99$ et Kolmogorov-Smirnov $p = 0.89$ sur les paramètres publiés, paramètres imposés. ξ ne bouge que de 0.5% si l'on déplace le seuil au pourcent de 95.

4. Ce que la donnée ne permet pas, et qu'on ne masque pas script 57, 67
 ▲ Biais de taille : OpRisk sur-représente les grandes institutions, la queue est probablement sous-estimée. Biais de troncature au seuil de collecte.
 ▲ Aucune base de date des enchevêtrements : 4329 transactions annuelles ne donnent aucun signal directionnel ($\alpha = -0.33$).
 ▲ Le second degré en aveugle de corpus reste à faire : la fiabilité inter-juges n'est pas mesurée.

II. Le mécanisme, et sa part indifférentiable

5. De la matrice de jugement à la matrice de contagion script 18, 20, 20
 $\pi_j = \sum_k \text{TRANS}_{jk}$ est l'émission du pilier j (la ligne émet) :

$$W_{jk} = g \frac{\text{max}_{jk}}{\text{max}_{jj}} \quad \pi_j = g \frac{\text{max}_{jj}}{\text{max}_{jj}}$$
 ■ g par état de conformité : 0.45 / 0.68 / 0.90, poids.
 ■ $\rho(W) = 0.506$ et $R_0 = 0.054$ à $g = 0.90$. Comme $\sum_{j,k} W_{jk} \leq g$:
 ■ sous-criticité garantie par construction, la cascade s'êteint toujours.



6. Le branchement, et la loi exacte de l'étendue script 18a
 Depuis un pilier j touché, chaque cible est tirée proportionnellement à TRANS_{jk}/π_j et infectée avec probabilité W_{jk} . La loi du nombre de piliers touchés est calculée exactement, sans Monte-Carlo, par récursion sur les 2⁵ sous-ensembles :

$$P(S) = R(S) \prod_{j \in A \text{ et } A} (1 - W_{jA})$$

où le produit est la probabilité qu'aucune frappe ne sorte de A .

7. Le cœur du problème : la direction n'est pas identifiée script 40, 43, 49
 Décomposition $W = S + A$, avec S symétrique (le lien) et A antisymétrique (le sens).
 ■ S est identifié : la co-occurrence se lit dans les données.
 ▲ A ne l'est pas : trois tests successifs le montrent. Placebo par permutation sur le pas annuel d'OpRisk, $z = -0.33$, aucun signal ; sur les post-mortems, $z = +3.93$ contre un nul de 8.4 ± 2.2 ; sur le corpus des tiers, $z = +5.12$.

Réponse : l'identification partielle. On énumère exhaustivement les 2¹⁰ = 1024 sommets de la boîte admissible $|A_{jk}| \leq tS_{jk}$, et l'on rapporte une bande, pas un point.

8. Amplification, et adaptations par pilier script 37, 38, 39
 $(I - W)^{-1} = I + W^0 + W^1 + \dots$: converge car $\rho(W) < 1$. La direction s'appuie qu'à partir de W^2 : c'est là que se joue la dépendance à l'ordre.
 ▲ Quasi par pilier : cinq quers Bâle observés, 0.87 à 1.37, non assignables aux piliers. Les 120 assignations bornent le SCR à ± 55 / +96%.
 ■ P4 (tiers) n'est pas un nuclé comme les autres : 191 victimes d'un seul choc (MOVEn) → choc commun, structure symétrique donc identifiable.

III. Ce qui sort, et à quelles conditions

9. Aggrégation et capital script 14, 14b, 21
 Modèle collectif, $L = \sum_{i=1}^N X_i^{\text{capitale}} = \sum_{i=1}^N L_{i,1} L_{i,2} L_{i,3}$ 60000 à 600000 années simulées, nombres aléatoires comme configurations.
 → $\rho(\text{SCR}) = \text{Var}_{R_0, L, Y}$, forme imposée par Solvabilité II.
 socle sans contagion 5275 M€
 ▲ avec contagion, ignorance directionnelle totale [6358 ; 8467] M€
 avec non-conformité $\Delta_{\text{DORA}} = 10927$ M€

10. Allocation aux cinq piliers : deux vues, deux questions script 20
 Shapley, vue source, pour le surcoût : $\varphi_j = \frac{1}{\sum_{i \in A} (1 - \frac{|A| - |i|}{|A|})} [\pi(A \cup \{j\}) - \pi(A)]$, avec $\pi(A) = \text{SCR}(A \text{ non conforme}) - \text{SCR}(\text{tous conformes})$. P1 concentre 34%, au-dessus de sa part d'annonce de 30% : la proportion déforme l'annonce.
 Euler, vue réciprocité, pour le niveau : $C_j = E[L_j | L \geq \text{Val}_{99.5\%}]$, prouvé plat.
 La répartition se décide citée source, le capital se loge côté réciprocité.

11. Descendre à l'échelle d'une entité, et emploi script 58, 60, 65
 λ in à la taille de l'entité, 0.092/an, et non choisi dans un seuil. Besoin de capital 169 M€, bornes [131.5 ; 183.3].
 Arbitrage déduit on transfère : le coût annuel du capital vult 2.2 fois la sinistralité attendue ; la portée optimale suit la loi, et la conformité fait tomber le coût total de 2.89 à 0.54 M€/an, soit -81%.
 ■ Quatre bilans SCR réels, entités anonymisées : le rapport au SCR public est une mise à l'échelle, pas une part.

12. Les réserves, publiques et non dissimulées script 46, 48, 51, 66
 ▲ Trois étages d'incertitude : paramètres $\times 2.5$: dépendances $\times 1.9$: famille de queues $\times 5.5$. Le niveau bouge dans la bande, l'ordre des piliers ne bouge pas.
 ▲ Le 109 M€ est une borne supérieure d'ordre de grandeur, pas une mesure : l'entité nationale tombe sous la borne admissible de validité de la descente.
 ■ Les trois g sont posés, mais la thèse n'en dépend pas : le capital est croissant en g (comme vérifié), donc la règle respecté produit l'écart. Seule l'amplitude est un avertisseur.
 → Ce n'est pas un SCR réglementaire : aucun module DORA n'existe en Formule Standard. On écrit le besoin de capital ORSA au titre de DORA s.

En fil, en une phrase : la donnée identifie le lien entre piliers, pas son sens ; on ne pose donc pas la direction, on l'encadre, et le classement des piliers survit à cet encadrement là où le niveau du capital, lui, n'y survit pas.

Chaque grandeur porte une pastille de statut : **estimée**, **posée**, **bornée** faute d'identification, ou **réglementaire**, pour qu'on puisse attaquer le modèle bloc par bloc.

La propagation, et pourquoi je publie une bande et non un point

Le mécanisme

Une matrice de propagation va du domaine **source** vers le domaine **cible**, normalisée pour que le domaine le plus prolifique engendre au plus g descendants directs. Rayon spectral 0,506, donc cascade **sous-critique**, et nombre de reproduction 0,054 : ce n'est pas un régime épidémique, c'est un amplificateur borné.

La difficulté centrale, et le choix qu'elle impose

Les bases d'incidents identifient la **co-occurrence** de deux domaines défaillants, pas l'ordre dans lequel ils ont cédé : en décomposant la matrice en parties symétrique et antisymétrique, la donnée identifie la première et **pas la seconde**, qui est la direction.

Je ne tranche donc pas arbitrairement : j'énumère les $2^{10} = 1\,024$ sommets de l'ensemble admissible et je publie l'**ensemble** des valeurs compatibles. Socle sans propagation 5 275 M€, bornes [6 858 ; 8 697]. Je peux dire que la propagation ajoute au socle, et de combien au plus et au moins, sans prétendre savoir de combien exactement.

J'avais posé au départ une propriété de **non-transitivité** de la propagation : je l'ai testée et réfutée moi-même, et elle est remplacée par une **dépendance à l'ordre**, plus faible et qui tient. Sources : scripts 03, 30 et 31.

Ce que le point du 7 août a produit

Trois choses, dont deux corrections de fond.

Une confusion d'échelles, levée

Je présentais sous la même étiquette un quantile de **sévérité**, sur un sinistre unique, et un besoin de capital, sur la **charge annuelle agrégée** : cela fait lire une différence d'échelle comme une incohérence, et la séance a buté là. Le vocabulaire est séparé et le passage d'une échelle à l'autre est calculé. Ce qui ferme la question : le rapport entre les deux **s'inverse selon l'échelle**, donc aucun rapport fixe ne les relie.

Le statut de la mesure de queue, précisé

Faut-il fonder le capital sur une espérance conditionnelle de queue plutôt que sur un quantile ? L'argument qui tranche n'est pas le degré de prudence mais l'**existence** : sur ma seconde source de sévérité, $\hat{\xi} = 1,033 > 1$, donc **la mesure n'est pas définie**. Je l'utilise en diagnostic, jamais en couverture.

Une comparaison retirée, et la calibration gelée

Je rapportais mon résultat à la charge forfaitaire de Formule Standard. J'ai retiré cette comparaison : le rapport varie d'un facteur cinquante selon la composition du bilan, donc son **niveau** ne mesure rien. Reste que le forfait est **identique quel que soit l'état de maîtrise** là où le modèle les écarte. Depuis, la calibration est gelée.

Sources : scripts 63, 65 et 67.

Votre remarque sur le quantile, et ce qu'elle a produit

Le point de départ était le vôtre

« Le quantile d'un objet incertain est mauvais ». Un capital pris comme quantile à 99,5 % d'une loi estimée en un point lit une queue sur données rares : 91 excès, $\hat{\xi} = 0,5954$, intervalle bootstrap à 90 % de $[0,30; 0,83]$.

Deux réponses construites, et elles ne disent pas la même chose

Le **quantile prédictif** intègre l'incertitude *avant* de prendre le quantile : c'est le quantile de la loi mélange sur la distribution bootstrap des paramètres. La **posture robuste** prend au contraire la borne haute sur un ensemble d'ambiguïté, à deux couches, le paramètre puis la famille de queue.

Le résultat m'a surpris, et je vous le rends tel qu'il est

À 99,5 % le prédictif vaut 645 M€ contre 657 pour le *plug-in*, et en moyenne sur les rééchantillonnages l'écart n'est que de 5 M€ pour un bruit de simulation de 7. **Intégrer l'incertitude ne déplace donc pas le point** à ce niveau ; elle ne le déplace qu'en profondeur, +4 % à 99,9 %. Ce qui était fragile n'était pas le point mais la **largeur** : l'intervalle bootstrap de cette même grandeur va de 411 à 1 037 M€, soit un facteur 2,5 par la seule incertitude de calibration.

Votre remarque tenait donc, mais **pas par le mécanisme que j'attendais** : elle ne condamne pas le quantile, elle condamne le quantile *cité seul*.

Sources : scripts 46, 47 et 51.

Demande 1 : quelle posture reporter

Posture	Ce qu'elle intègre	Niveau	bruit
Point (<i>plug-in</i>)	rien : quantile d'un ajustement ponctuel	657	—
Prédictive	l'incertitude de paramètre, <i>avant</i> le quantile	645	± 7
Robuste $\beta = 90\%$	borne haute sur l'ambiguïté de paramètre	939	± 13
Robuste $\beta = 95\%$	idem, prudence plus élevée	1 037	± 9
Robuste $\beta = 99\%$	idem, et la plus bruitée des six	1 247	± 24
Pire-cas de modèle	on ajoute l'ambiguïté de <i>famille</i> ($\xi = 0,90$)	1 331	—

En M€, bruit = écart-type sur quatre rééchantillonnages bootstrap. **Les deux extrémités de l'échelle sont exactes**, le point et le pire-cas ne comportant aucune simulation : tout le bruit est au milieu, dans les postures qui intègrent l'incertitude, donc une posture plus riche est moins reproductible. **Et la plus prudente est la moins précise**. À ne pas surinterpréter : sur quatre graines, l'ordre entre $\beta = 90$ et 95% n'est pas résolu et n'a pas à l'être ; seul le saut vers $\beta = 99\%$ est net.

Ma question, et c'est la seule qui appelle une décision de votre part

Je reporte aujourd'hui le **plug-in avec sa bande**, et je présente l'échelle comme un axe de sensibilité. Est-ce le bon choix, ou faut-il reporter la **prédictive**, plus honnête sur l'estimation et sans coût en niveau ? Passer au **robuste 95%** multiplierait le résultat par 1,6 : cela relève d'une politique prudentielle, et je ne pense pas que ce soit à moi de le décider seul.

Sources : scripts 46 et 51.

Demandes 2 à 4 : trois questions de méthode

2. Ma sévérité n'est pas plafonnée quand je descends à une entité

L'élasticité de la sévérité à la taille vaut 0,087, intervalle $[0,026 ; 0,148]$, donc **très proche de zéro à sa borne basse**. Le modèle affirme donc qu'une entité de quelques milliards subit à peu près la sévérité d'une institution mondiale. D'où une **borne inférieure de taille** sous laquelle la transposition n'est plus crédible, et la requalification de mon résultat d'entité en borne supérieure. Le correctif que je vois, un plafond adossé à l'exposition propre, déplacerait tous mes résultats d'entité et je suis en gel de calibration. **Peut-on borner ce biais sans recalibrer ?**

3. Mon capital est un capital de queue

La base est tronquée à son seuil de collecte : la composante **attritionnelle** en est absente, par absence d'observation et non par choix. Deux atténuations : le quantile est porté par un sinistre unique, et à l'échelle d'une entité 98,8 % des années sont sans incident matériel. Je déclare la limite avec son sens, elle sous-estime, sans chiffrer sa taille. **Suffisant, ou faut-il reconstruire la partie tronquée ?**

4. Mon intervalle de confiance est trop étroit

La couverture réelle de mon intervalle à 90 % sur l'indice de queue vaut 86 % : l'incertitude sur $\hat{\xi}$ est **sous-estimée**, d'environ 10 % en demi-largeur. Je l'ai signalé plutôt que corrigé. **Correction reconnue, ou publier la sous-couverture ?**

Sources : scripts 47, 57, 60 et 65.

Si le temps le permet : comment la conformité entre dans la loi de perte

Un point de modélisation non trivial, qui emprunte à votre logique d'états de conformité.

La conformité n'ajoute pas une pénalité, elle déplace quatre paramètres

Passer de l'état conforme à l'état non conforme ne surcharge pas le capital d'un terme additionnel : cela déplace la **fréquence** de 21,6 à 53,6, le **taux de détection** de 0,128 à 0,181, le **gain de propagation** de 0,45 à 0,90, et un terme d'**accumulation** de 0 à 0,68.

Et ces quatre canaux ne s'additionnent pas

Pris isolément ils somment à 9 138 M€ quand l'écart total vaut 14 139 : +5 001 M€ **d'interaction, soit +35 %**. La propagation est super-additive, ce qui interdit d'additionner des leviers de remédiation pour chiffrer un plan partiel. Deux canaux sont calibrables, la fréquence et la détection ; les deux autres sont *bornés*, et je ne promets donc pas une remédiation là où je n'ai qu'une borne.

Un point qui ne dépend pas de moi. Ce qui identifie la *direction* de la propagation est un corpus de rapports d'enquête que j'ai codé seul, et la fiabilité inter-juges attend un **second codage en aveugle** : dix récits, une heure, kit prêt, et cela ne demande pas un expert du domaine. Auriez-vous un nom à me suggérer ? Sources : scripts 20, 43 et 54.